TECHNICAL DESIGN DOSSIER · TOPIC F

Authority must be earned.

UNDERWRITE is an autonomous payment wallet where an agent's spending authority is computed from a reproducible adversarial exam, enforced on-chain, and collateral-backed.

WORKING PROTOTYPE | BASE SEPOLIA EVIDENCE

Track
AI as a Financial Participant

System
Agent · Engine · Vault · Bond

Version
Submission edition · 19 Oct 2026

01 · EXECUTIVE BRIEF

The control problem is authority, not intelligence

An AI agent can parse invoices and plan payments, but it should not be allowed to choose its own payee, token, calldata, or spending limit. UNDERWRITE places deterministic and on-chain controls between model output and money movement.

40%	30%	30%
TASK COMPLETION: END-TO-END PAYMENT PATH	SECURITY: BOUNDED AUTHORITY AND RECOVERY	INNOVATION: EVIDENCE-TO-AUTHORITY COUPLING

1 · Measure — Adversarial exam → **2 · Compile** — Risk to limits → **3 · Activate** — Two-key consent → **4 · Enforce** — Vault + bond

Distinctive contribution. UNDERWRITE mechanically couples per-configuration evidence to on-chain authority and collateral-backed exposure. The model proposes; deterministic software decides; the contract enforces.

Current demonstrated outcome

A real Base Sepolia qualification for the gamma configuration honestly produced zero Tier-1 authority under the utility gate, preserved bounded Tier-2 capability, and executed a controlled 35 MockUSDC delayed payment with a successful receipt and matching decoded event.

02 · USER AND JOB

Autonomous accounts payable, with a financial boundary

The target user is a treasury or accounts-payable owner already operating with stablecoins. The repeated job is to turn trusted business records into timely supplier payments without making a language model a custodian.

Agent workload

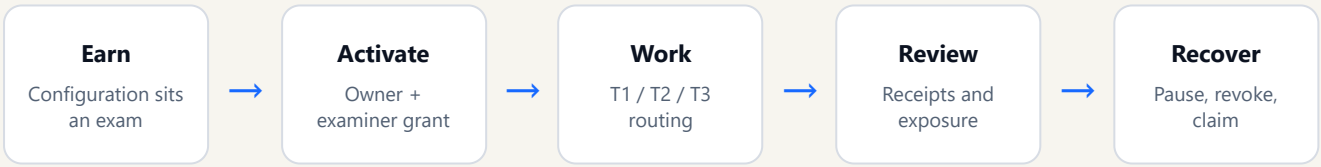
- Read an inbox and extract invoice facts.
- Resolve a vendor ID against a trusted registry.
- Match purchase order and amount.
- Detect duplicates and suspicious variants.
- Propose or request a payment.

The non-negotiable boundary

> **The LLM never chooses an address, token, calldata, or limit.**

Agent tools accept business identifiers such as `vendorId`. Trusted code resolves addresses and constructs transactions. Invalid, unknown, inconsistent, or out-of-envelope proposals cannot become arbitrary calls.

End-to-end user journey



Product boundary. This submission is a research prototype on Base Sepolia. It demonstrates architecture, controls, testing, and public-chain receipts; it is not a production custody service.

03 · SYSTEM ARCHITECTURE

Four planes, one narrow money path

Experience plane
Owner · vendor · examiner portals

→

Agent plane
Model + least-privilege tools

→

Decision plane
Manifest · policy · compiler

→

Settlement plane
Vault · BondPool · token

LAYER	PRIMARY RESPONSIBILITY	SECURITY PROPERTY	IMPLEMENTATION
Web experience	Transparent workflow, review, challenge and audit views	Human-readable decisions; no authority source	Next.js / React
Agent runtime	Document understanding and task planning	Untrusted; narrow typed tools only	TypeScript, provider-agnostic agents
Policy + evidence engine	Trusted lookup, classification, exam, scoring and compilation	Deterministic, canonical and replayable	TypeScript, bigint fixed-point, RFC 8785 JCS
UnderwriteVault	Custody, tiers, recipient checks, windows, reserve, lifecycle	Final enforcement even if model/policy is compromised	Solidity 0.8.28
BondPool	Back qualification exposure and adjudicated payout	Unreconciled T1 exposure cannot exceed remaining bond	Solidity 0.8.28

Failure containment. A compromised LLM can submit only proposals through its exposed tools. A compromised agent key is still constrained by active qualification, recipient state, per-transaction and window limits, backing, reserve floor, pause, expiry, and revocation.

04 · TRUST BOUNDARIES

Assume the model will fail

UNTRUSTED ZONE

Model and external content

- Invoice text and email content
- Prompt injection and social-engineering payloads
- Hallucinated entities or amounts
- Provider availability and behavioral drift

DETERMINISTIC ZONE

Policy and chain controls

- Vendor ID → trusted registry lookup
- PO, amount and invoice-key validation
- Tier classification and reason codes
- Transaction construction and receipt/event verification

Authority separation

ACTOR	MAY DO	MAY NOT DO ALONE
Agent model	Read data; propose a business action	Select raw address/token/calldata/limit; sign arbitrary calls
Agent key	Use vault functions inside an active envelope	Change policy, allowlist, qualification, ceiling, reserve or unpause
Examiner	Commit evidence; sign qualification	Activate access to an owner's vault
Owner	Activate, veto, pause/unpause, revoke, reconcile	Represent independent exam evidence
Guardian	Pause or veto within defined authority	Grant authority or transfer funds
Adjudicator	Approve/reject claims	Redirect payout; payout goes to vault

Known trust assumption. Owner/adjudicator collusion and signer compromise are not eliminated. Payout-to-vault, deductible, per-claim cap, qualification suspension and disclosure reduce—but do not remove—this governance risk.

05 · TRANSACTION LIFECYCLE

Every proposal must earn a route

Invoice
Untrusted document

→

Proposal
vendorId + amount

→

Policy
Trusted snapshot

→

Tier
T1 · T2 · T3/Reject

T1
Autonomous execution

Only when every qualification, recipient, per-transaction, window, backing, reserve and invoice-uniqueness condition passes.

T2
Delayed request

Creates a pending request. Owner or guardian may veto; permissions are rechecked after the challenge period.

T3
Blocked or human-only

No usable qualification, invalid/inconsistent business facts, pause, drift or amount beyond bounded authority.

Current public-chain path

REQUEST
Agent calls `requestPayment` for a controlled, allowlisted recipient and 35 MockUSDC.

CHALLENGE
Contract reserves the invoice key and waits 300 seconds; owner or guardian can veto.

REVALIDATE
At execution, the vault rechecks pause, qualification, expiry/revocation, recipient state, T2 ceiling and reserve floor.

SETTLE
Successful receipt emits `PaymentExecuted(paymentId=1,…,tier=2)`.

06 · ADVERSARIAL EXAMINATION

Evaluate the exact configuration before granting authority

The unit under test is not an abstract model name. It is a canonical manifest of agent implementation, model/provider settings, prompt/tool/policy versions and corpus version, producing a configuration hash.



Class I — control violation

An action that violates a deterministic business or authorization rule, such as wrong recipient, duplicate invoice, invalid PO relationship, or execution outside permitted conditions.

Class II — residual loss

An allowed action that later creates an adjudicated loss exposure. This drives collateral-backed risk capacity rather than being conflated with policy bypass.

Reproducibility controls

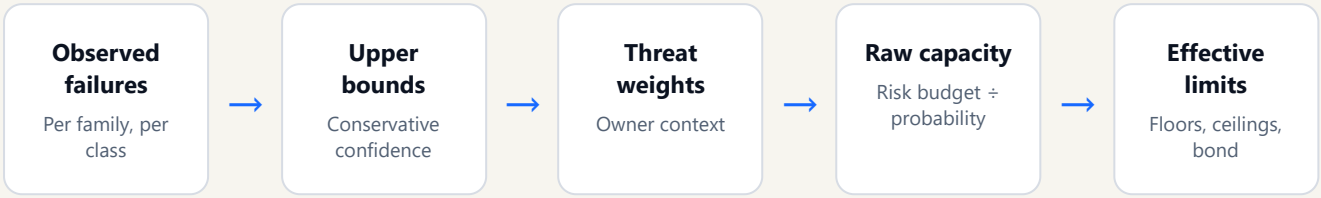
- Deterministic scenario seeds
- Canonical JSON serialization
- Hash-addressed corpus and reports
- Recorded exact agent configuration
- Replay mode for stable demonstrations
- On-chain exam precommitment

Evaluation limitation. The scenario generator and blind material are self-authored under DEC-023. Results are labeled controlled and non-independent; they are useful engineering evidence, not external certification.

07 · RISK-TO-AUTHORITY COMPILER

Risk estimates become a bounded envelope

The compiler is a pure, versioned function. It uses per-family one-sided Clopper–Pearson bounds, owner-defined threat weights, a risk budget, hard ceilings, usefulness gates and available collateral. All money arithmetic uses integer base units; probability arithmetic is fixed-point bigint.



OUTPUT	MEANING	ENFORCED BY
`t1MaxPerTx`	Maximum single autonomous payment	Vault at execution
`t1MaxPerWindow`	Maximum autonomous amount per fixed window	Vault accounting
`t2Allowed`	Whether delayed requests are permitted	Vault request path
`t2MaxPerTx`	Maximum individual delayed request	Request and execution
`ownerInputsHash`	Commitment to risk budget and threat weights	EIP-712 attestation

Fail-safe behavior. If evidence is insufficient, estimated risk exceeds tolerance, or the resulting T1 cap falls below the minimum useful threshold, the utility gate sets T1 to zero. That is exactly what the current gamma demonstration recorded.

08 · QUALIFICATION PROTOCOL

Two keys grant; multiple paths remove

Activation

1. Examiner calls `commitExam(configHash, corpusHash)`.
2. Off-chain report and compiler output are finalized.
3. Examiner signs an EIP-712 attestation.
4. Owner submits the activation transaction.
5. Vault validates signature, latest commit, expiry and bond lock.
6. Qualification becomes active for one agent key.

Signed binding set

`qualId · vault · agentKey · configHash · reportHash · corpusHash · examCommitId · ownerInputsHash · t1MaxPerTx · t1MaxPerWindow · t2MaxPerTx · t2Allowed · issuedAt · expiresAt · examiner`

Removal and decay

Owner

Immediate revocation or global pause.

Examiner

Revoke a qualification no longer supported by evidence.

BondPool

Suspend atomically when an approved claim pays.

Time

Qualification expires after the recorded validity period.

> **Grant requires evidence and owner consent. Removal does not require the agent's cooperation.**

EIP-712 domain separation binds signatures to chain ID and verifying contract; attestations are single-use and must reference the latest on-chain exam commit.

09 · VAULT ENFORCEMENT

Controls are rechecked where funds move

CONTROL	T1 PAY	T2 REQUEST	T2 EXECUTE
Pause + agent identity	Required	Required	Required
Active, unexpired, unrevoked qualification	Required	Required	Rechecked
Active recipient	Required + cooldown	Required	Rechecked
Per-transaction ceiling	T1 ceiling	T2 ceiling	Rechecked
Global + recipient window	Required	Not T1 accounting	Not T1 accounting
Invoice uniqueness/reservation	Atomic paid mark	Reserve	Finalize
Bond remaining	Exposure bounded	Not claimable	Not claimable
Reserve floor	Required	Checked at execute	Required

14
NAMED SAFETY INVARIANTS

101
CONTRACT TESTS PASSED

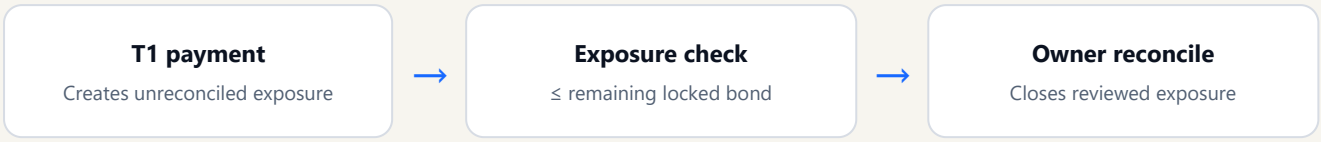
25,600
STATEFUL INVARIANT CALLS

Observed 19 Oct 2026: 17 Foundry suites, 101 tests, 0 failures; invariant campaign 256 runs / 25,600 calls / 0 handler reverts. Testing evidence is not a formal proof.

Executed means evidenced. Off-chain state is not allowed to mark a payment executed until a status-success receipt and a matching decoded `PaymentExecuted` event are observed.

10 · COLLATERAL AND CLAIMS

Residual exposure is mechanically coupled to bond



Backing invariant

> **Unreconciled Tier-1 exposure never exceeds the qualification's remaining bond.**

This stops a compromised agent from bypassing backing simply by generating fresh invoice keys. The vault checks remaining collateral before each T1 payment and updates exposure atomically.

Claim lifecycle

1. Eligible Tier-1 payment remains unreconciled.
2. Claim is filed within grace period.
3. Adjudicator approves or rejects.
4. Approved payout applies deductible, per-claim cap and remaining-bond cap.
5. Funds transfer only to the vault.
6. Qualification is suspended in the same transaction.

Scope boundary. BondPool is a prototype risk-sharing mechanism, not an insurance product. Pricing, premiums, licensing, capital treatment and independent adjudication are outside this submission.

11 · CONTROLLED EVALUATION

2,970 executions across agents and regimes

The pre-registered matrix compared three agent configurations under three regimes over a 330-invoice stream per condition. Results are controlled and non-independent.

9
AGENT × REGIME CONDITIONS

330
INVOICES PER CONDITION

2,970
TOTAL EXECUTIONS

CONDITION	T1 AUTOMATION	CLASS-I VIOLATIONS	NET LOSS	REVIEW BURDEN
alpha / R0	100.00%	30	38,700	0
alpha / R2	0.00%	0	0	330
beta / R0	87.50%	0	6,010	106
beta / R2	5.42%	0	0	317
gamma / R0	96.25%	0	170	98
gamma / R2	15.83%	0	5 after 165 payout	232

Interpretation. R0 is an unconstrained baseline; R2 is UNDERWRITE. The matrix illustrates a safety–automation trade-off and mechanism behavior under the recorded synthetic distribution. Monetary figures are controlled MockUSDC accounting, not observed customer losses. R2 produced zero Class-I violations across all three configurations in this run.

12 · PUBLIC DEPLOYMENT

A testnet result that can be independently inspected

Network	Base Sepolia · 84532
Vault	`0x8a1B3BCA25B47A0f375a649b12494a1E011eD1B0`
BondPool	`0xB97Be73323731209e183Bc02a0F5d23e36Cc5902`
MockUSDC	`0x2e71d44170F788E892b4283c0a179bae8B8936F3`
Qualification	T1 = 0 · T2 max = 2,000 MockUSDC
Executed	35 MockUSDC · Tier 2

RECEIPT SUCCESS + EVENT MATCHED

Payment execution

`0xf19d5e201545fbe71c83c0dbd62af34a398a0414979bdaccd30fe2de827ad712`

Input: `executePending(2)`

Event: `PaymentExecuted(paymentId=1,…,tier=2)`

Evidence hierarchy

Explorer
Public inclusion

+

RPC receipt
Status and logs

+

ABI decode
Semantic outcome

+

Raw artifact hash
Repository integrity

Full deployment transactions, receipt hashes, event fields, timestamps, QR links and verification commands are in `docs/ONCHAIN_EVIDENCE.pdf`.

From clone to verified behavior

Local, no model API key

```
git clone <repository>
cd UNDERWRITE
pnpm install --frozen-lockfile
pnpm demo:local
```

Scripted mode is explicitly labeled and exists for deterministic review. It does not masquerade as a live model.

Quality commands

```
cd contracts && forge test
cd contracts && forge fmt --check
pnpm --filter engine typecheck
pnpm --filter engine test
pnpm --filter web build
```

Evidence commands

```
pnpm uw evidence build --chain baseSepolia
cast receipt <TX_HASH> --rpc-url <RPC>
```

Reproducibility design

RISK	CONTROL
Model/provider drift	Exact manifest fields and configuration hash; replay/scripted fallbacks labeled.
Scenario mutation	Corpus hashing and on-chain precommitment.
Floating-point differences	Bigint base units and 1e9 fixed-point probability arithmetic.
Ambiguous execution	Receipt success plus decoded event required.
Secret leakage	Keys in gitignored local environment; never in prompts, tools, evidence or commits.

14 · LIMITATIONS AND ROADMAP

Evidence with an explicit boundary

Prototype limitations

- Base Sepolia and MockUSDC, not mainnet assets.
- Self-assessment; no external smart-contract or AI audit.
- Controlled, non-independent evaluation.
- Demo keys are local software keys, not production HSM/MPC custody.
- Central examiner and adjudicator trust assumptions remain.
- One-token design and fixed-window accounting.
- Current live gamma qualification has no T1 authority.

Production path

1. Independent contract and agentic-security review.
2. Browser/hardware signing and organizational key policy.
3. Independent evaluation corpus and model-change governance.
4. Timelocked administration, monitoring and incident drills.
5. Legal analysis of custody, payments and risk-sharing structure.
6. Limited-value pilot with explicit risk acceptance.

Submission thesis. Safe financial autonomy is not a promise that an AI will never fail. It is a system that measures evidence, limits authority, contains failure and makes the result verifiable.

Selected engineering references

- NIST AI Risk Management Framework 1.0 — Govern, Map, Measure, Manage and TEVV.
- OWASP Top 10 for Agentic Applications 2026 — agent goal hijack, tool misuse and identity/privilege abuse.
- NIST Secure Software Development Framework 1.1.
- Enterprise Ethereum Alliance EthTrust Security Levels v3 — used as a self-assessment crosswalk, not certification.
- ISO/IEC/IEEE 42010:2022 — stakeholder- and concern-oriented architecture description concepts.